ЛЕКЦИЯ 5 • УПРАВЛЕНИЕ НА РИСКА ПРИ ИТ ПРОЕКТИ

Матрица за оценка на риска за ИТ проект

Идентификация, оценка, план за отговор и контрол на рисковете при мобилното приложение за лични финанси

Технически университет – София • Управление на проекти • Упражнение

Съдържание

Мобилно приложение за лични финанси: продължение на проекта от Лекции 3 и 4

01 Изходни данни от предишните лекции, процес и скали

02 Идентификация: структура за разбивка на риска и профил на риска

03 Оценка: регистър, матрица, FMEA и PERT

04 План за отговор и рискове на AI интеграцията

05 Контрол, защо тези рискове са приоритетни, изводи

01 • ИЗХОДНИ ДАННИ

Какво носим от предишните лекции

Голяма част от рисковете вече се появиха в анализа. Сега ги събираме и оценяваме на едно място

Лекция 1 • Жизнен цикъл

- Рисковете се идентифицират още в началната фаза
- Контролът тече паралелно с всички фази до приключването

Лекция 2 • SWOT

- Заплахите „сигурност и GDPR“ и „зависимост от банкови API“ стават рискове С1, П1 и Т1
- Слабостта „малък екип“ става риск О1

Лекция 3 • Обхват

- Матрица: времето е фиксирано, затова рисковете за срока тежат най-много
- MoSCoW и „Won't“ ограничават риска от разширяване на обхвата (О2)

Лекция 4 • Оценка

- Базов бюджет 61 644 € + резерв 6 164 €
- Три-точковата оценка става вход за PERT
- AI съветите са във версия 1.1

Въпросът сега: какво може да ни попречи да пуснем версия 1.0 до месец 6 в рамките на този бюджет, и какво правим предварително, за да не се случи.

Четирите стъпки и как оценяваме

Процесът от лекцията и общи скали, за да може всеки член на екипа да оценява еднакво

1 Идентификация
Мозъчна атака с екипа, разбивка на риска, профил

2 Оценка
Вероятност × въздействие, FMEA и PERT

3 План за отговор
Избягване, намаляване, прехвърляне, приемане

4 Контрол
Регистър, отговорници, сигнали, срещи

Вероятност	В рамките на проекта
1 • много ниска	< 10%
2 • ниска	10–30%
3 • средна	30–50%
4 • висока	50–70%
5 • много висока	> 70%

Въздействие	Срок или бюджет
1 • незначително	< 2 дни, < 500 €
2 • малко	< 1 седм., < 1 500 €
3 • умерено	1–2 седм., до 3 000 €
4 • голямо	2–4 седм., до резерва
5 • критично	> 1 мес., глоба, спиране

Оценка = В × Вз (1–25)

15–25 висок приоритет: действие веднага, отговорник, сигнал

6–12 среден: мярка в плана, преглед всеки месец

1–5 нисък: приемаме и наблюдаваме

Въздействие 4 = до резерва от 6 164 € (Лекция 4).

02 • ИДЕНТИФИКАЦИЯ

Разбивка на риска и профил на риска

Въпросите от лекцията, зададени за нашия проект. Всеки отговор „не“ или „частично“ става риск

Категория	Въпрос от профила	Отговор при нас	Риск
Технически	Стабилни ли са изискванията към външните системи?	Не: всяка банка връща данните различно	Т1
Технически	Има ли зависимост от график, който не контролираме?	Да: прегледът в App Store и Google Play	Т3
Бюджет	Има ли риск от превишаване поради непредвидени разходи?	Да: песимистичната оценка на 2.2 е 110 дни	Т2
Сигурност	Има ли планирани тестови среди и проверки за качество?	Частично: тестът за проникване е чак в месец 4	С1
Сигурност	Как се тества функция, чиито отговори не са предвидими?	Само вътрешно: AI съветите (v1.1)	С2
Правни	Знаем ли какви са изискванията на GDPR и PSD2?	Частично: имаме една правна консултация	П1
Контрактори	Ясни ли са условията с външните доставчици?	Частично: цената на агрегатора не е фиксирана	П2
Персонал	Разполага ли екипът с нужните умения и заместници?	Не: двама разработчици, без резерва	О1
Клиент	Разбира ли клиентът обхвата и неговите граници?	Частично: иска инвестиции и семейни сметки	О2
Управление	Одобрен ли е бюджетът от всички?	Не още: базата е с 1 644 € над тавана	О3

Четири категории от разбивката: технически (Т), сигурност (С), правни (П), организационни (О). Така по-трудно пропускаме цяла група рискове.

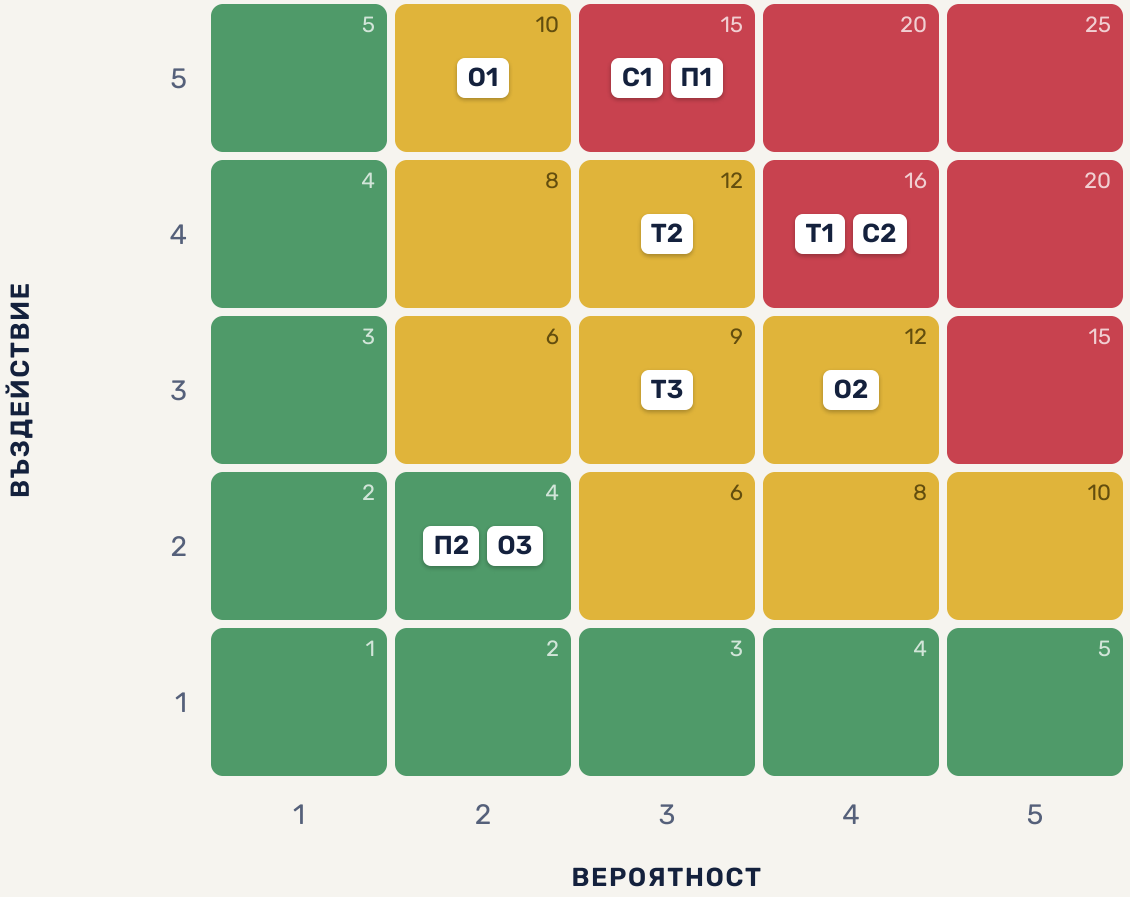
Регистър на рисковете

10 риска в 4 категории, оценени по скалите от слайд 4

№	Рисково събитие	Категория	В	Вз	Оценка	Отговор
Т1	Банките връщат данни в различен вид през агрегатора, пакет 2.3 расте от 22 до 40 дни	Технически	4	4	16	Намаляване
С2	AI съветите дават неверни суми или инвестиционен съвет, prompt injection през описанията на транзакциите	Сигурност	4	4	16	Избягване
С1	Изтичане на финансови данни или критична уязвимост, открита късно	Сигурност	3	5	15	Прехвърляне
П1	Нарушение на GDPR или PSD2 при съхранение на данни и съгласия	Правни	3	5	15	Избягване
Т2	Основните функции (2.2) отнемат повече от най-вероятните 80 дни	Технически	3	4	12	Намаляване
О2	Клиентът иска нови функции („Won't“ за v1) по време на разработката	Организационни	4	3	12	Избягване
О1	Напуска или се разболява един от двамата разработчици	Организационни	2	5	10	Намаляване
Т3	App Store или Google Play отхвърлят първата версия	Технически	3	3	9	Намаляване
П2	Агрегаторът вдига цената си след пилотния период	Правни	2	2	4	Приемане
О3	Спонсорът не одобрява превишението от 1 644 € над тавана	Организационни	2	2	4	Приемане

Матрица за оценка на риска

Хоризонтално е вероятността, вертикално е въздействието



Червено • 4 риска

Т1, С2, С1, П1. Три от тях са сигурност и право. Това са рисковете, които могат да спрат пускането или да доведат до глоба.

Жълто • 4 риска

Т2, О2, О1, Т3. Удрят главно срока, който е фиксиран, затова имат мярка в плана.

Зелено • 2 риска

П2, О3. Покриват се от резерва или от решението от Лекция 4 (отлагаме функция „Should“).

FMEA: колко лесно ще забележим риска

Въздействие × вероятност × откриване (1 = веднага се вижда, 5 = почти невидим). Прилагаме го за червените рискове

Риск	Вз	В	Откр.	Стойност	Защо такова откриване
С2 AI съвети	4	4	4	**64**	Грешният отговор изглежда правдоподобен
С1 Изтичане	5	3	4	**60**	Уязвимостта не се вижда до атака или тест
П1 GDPR/PSD2	5	3	3	**45**	Вижда се при правна проверка
Т1 Банкови API	4	4	2	**32**	Прототипът в месец 1 го показва веднага

Подредбата се сменя

В матрицата Т1 беше първи. По FMEA е последен, защото го откриваме рано и евтино. Първи излизат AI съветите и сигурността.

Внимание от лекцията

Еднаква стойност не значи еднакъв риск. Затова гледаме и трите числа, а не само произведението.

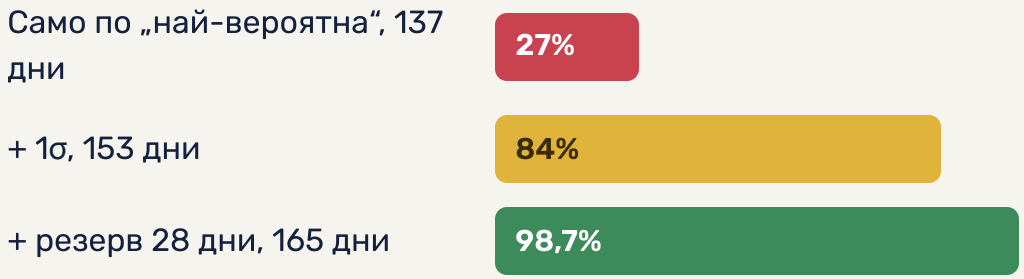
Извод: за С1 и С2 не стига да намалим вероятността. Трябва и по-добро откриване, т.е. външно тестване. За него има отделен ред в бюджета (слайд 11).

PERT: вероятност да се вместим в плана

Три-точковата оценка от Лекция 4 за пакетите на критичния път на v1.0 (AI съветите са във v1.1)

Пакет (човекодни)	О	Н	П	Очаквана	σ
2.2 Основни функции	65	80	110	82,5	7,5
2.3 Банкови API	15	22	40	23,8	4,2
2.4 Тестване	25	35	55	36,7	5,0
Общо	**105**	**137**	**205**	**143,0**	**9,9**

Очаквана = (О + 4Н + П) / 6, σ = (П − О) / 6, σ на общото = √(Σσ²). Мрежа: дизайн → основни функции → банкови API → тестване → пускане.



Какво казва PERT: ако планираме само по най-вероятните оценки, има около 73% шанс да ги превишим. Резервът от 28 човекодни (≈ 6 164 €) от Лекция 4 вдига шанса до 98,7%. Затова Т2 е жълт, а не червен: покрит е от резерва, ако той не се похарчи за други рискове.

План за отговор по стратегии

И четирите стратегии от лекцията са използвани. Всеки риск има мярка и отговорник

Избягване

П1 С2 О2

П1: не пазим банкови пароли. Достъпът е само през лицензиран агрегатор, а данните са в ЕС.

С2: AI съветите не влизат във v1.0. Във v1.1 само след външен тест.

О2: списъкът „Won't“ е в договора. Нова функция влиза само ако друга излезе.

Намаляване

Т1 Т2 О1 Т3

Т1: прототип с 2 банки в тестовата среда на агрегатора в месец 1.

Т2: седмичен план–факт за 2.2, преоценка след MVP.

О1: преглед на кода от двамата, документация.

Т3: подаване 3 седмици преди срока.

Прехвърляне

С1

Тестът за проникване е от външна фирма с договорна отговорност. Застраховка за кибер риск ≈ 1 200 € годишно от общите разходи.

Плюс намаляване: тестът е в месец 4, а не в края, и има правила за сигурност от първия спринт.

Приемане

П2 О3

П2: по-високата цена на агрегатора се покрива от резерва.

О3: при отказ отлагаме функция „Should“ (известия при превишен бюджет), без да местим срока.

Активно приемане: знаем какво правим, ако се случи.

Рискът C2 и външното тестване на AI

Най-високият риск по FMEA. Колко струва и колко време отнема тестването на самата интеграция

Пакет AI съвети (v1.1), след мярката

Разработка, 10 дни, и вътрешен QA, 5 дни	3 000 €
LLM API за разработка и регресионни тестове	300 €
Външно тестване: беше 500 € в Лекция 4	**1 500 €**
Общо с общи разходи и резерв	**≈ 5 800 €**

Ръстът от 1 000 € е цената на по-доброто откриване (FMEA: от 4 на 2 → стойност от 64 на 32).

Какво тества външният екип

- 200 тестови профила: без инвестиционни съвети, без измислени суми
- Prompt injection през описанията на транзакциите
- Лични данни не стигат до доставчика на модела (GDPR)
- Отговор под 3 секунди, цена на заявка
- **Праг:** над 2% грешни отговора и v1.1 не излиза

Време

16 ± 4 дни разработка + 2 седмици външен тест и поправки (беше 1 седмица). Месеци 7–8, извън критичния път на v1.0.

AI като инструмент за рисковете

Използвахме AI в мозъчната атака: ≈ 1 час + 2 часа проверка (≈ 80 €). Предложи Т3 и П2, които бяхме пропуснали. Оценките са на екипа.

05 · КОНТРОЛ

Контрол на мерките

Регистърът е жив документ: всеки риск има отговорник и сигнал, при който се задейства резервният план

Риск	Отговорник	Сигнал (кога действаме)	Резервен план
Т1	Разработчик 1	Прототипът не чете данни от 2 банки до края на месец 1	MVP с 1 банка + ръчно въвеждане
С2	QA + външен екип	Над 2% грешни отговора в 200-те профила	v1.1 без AI, само статистики
С1	QA	Критична находка в теста за проникване (месец 4)	Буферът от 2 седмици отива за поправки
П1	Ръководител + юрист	Юристът отбележи несъответствие при прегледа в месец 2	Промяна в потока за съгласие преди бета
Т2	Ръководител	Под 80% изпълнение на 2.2 в края на месец 3	Резерв + функция „Should“ във v1.1
О2	Ръководител	Ново искане извън „Must“ и „Should“	Искане за промяна, решение от спонсора

Срещи

Рисковете са точка от седмичната среща. Всеки месец преглед на целия регистър със спонсора.

Резерв

6 164 € се отпускат само от ръководителя при сигнал. Следим колко бързо се харчи.

Нови рискове

Влизат в регистъра със същите скали. След всеки ключов етап се правят нова оценка и нова матрица.

Защо тези рискове са приоритетни

Коментар към матрицата, до 200 думи

Приложението работи с банкови данни на хора, затова най-тежките рискове не са техническите, а сигурността и правото (С1, П1). Те могат да спрат пускането или да доведат до глоба, която е по-голяма от целия бюджет. Т1 е червен, защото цялата стойност на продукта е в автоматичното четене на сметките, а зависим от външен агрегатор.

FMEA показа, че AI съветите (С2) са най-опасни, защото грешката е трудна за забелязване. Затова ги избегнахме във v1.0 и платихме за външно тестване във v1.1.

Жълтите рискове удрят срока, който по приоритетната матрица е фиксиран. PERT показа, че без резерва има 73% шанс за закъснение. Зелените рискове приемаме, защото имаме готово решение от Лекция 4.

1. Матрицата не е достатъчна сама

FMEA и PERT смениха подредбата и обосноваха резерва.

2. Предишните лекции вършат работа

SWOT даде рисковете, MoSCoW даде мерките, оценката даде резерва.

3. Рискът се управлява и с пари

+1 000 € за външен AI тест струват по-малко от грешен финансов съвет.

Благодарим!

Въпроси и дискусия

РЕЗЕРВЕН СЛАЙД

Въпросите от лекцията

Ако преподавателят ги зададе след презентацията

1 **За какво служи структурата за разбивка на риска (RBS)?**

Подрежда рисковете по категории (технически, сигурност, правни, организационни). Така по-трудно пропускаме цяла група рискове. При нас към всяка категория има въпроси от профила (слайд 5).

2 **Каква е разликата между избягване и приемане?**

При избягването променяме плана, за да няма риск: AI съветите излизат от v1.0. При приемането не правим нищо предварително, а го покриваме, ако се случи: по-високата цена на агрегатора идва от резерва.

3 **Какво е PERT?**

Метод с три оценки за всяка дейност (О, Н, П), очаквано време (О + 4Н + П) / 6 и стандартно отклонение. Така получаваме вероятност да спазим срока. При нас: 27% без резерв и 98,7% с резерва (слайд 9).